

A. Introduction

1. **Title:** Cyber Security — Security Management Controls
2. **Number:** RRC-CIP-003-1
3. **Purpose:** To specify consistent and sustainable security management controls that establish responsibility and accountability to protect Bulk Electric Systems (BES) Cyber Systems (BCS) against compromise that could lead to misoperation or instability in the Railbelt Region BES.
4. **Applicability:**
 - 4.1. **Functional Entities:** For the purpose of the requirements contained herein, the following list of functional entities will be collectively referred to as “Responsible Entities.” For requirements in this standard where a specific functional entity or subset of functional entities are the applicable entity or entities, the functional entity or entities are specified explicitly.
 - 4.1.1. **Balancing Authority**
 - 4.1.2. **Generator Operator**
 - 4.1.3. **Generator Owner**
 - 4.1.4. **Transmission Operator**
 - 4.1.5. **Transmission Owner**
 - 4.1.6. **Distribution Provider:** that owns one or more of the following Facilities, systems, and equipment for the protection or restoration of the BES:
 - 4.1.6.1. Each underfrequency load shedding (UFLS) or undervoltage loadshedding (UVLS) system that:
 - 4.1.6.1.1. is part of a Load shedding program that is subject to one or more requirements in an Railbelt Reliability Council Standard; and
 - 4.1.6.1.2. performs automatic Load shedding under a common control system owned by the Responsible Entity, without human operator initiation that the loss, compromise, or misuse of could have adverse impact on the reliable operation of the BES.
 - 4.1.6.2. Each Remedial Action Scheme (RAS) where the RAS is subject to one or more requirements in an Railbelt Reliability Council Standard.
 - 4.1.6.3. Each Protection System (excluding UFLS and UVLS) that applies to Transmission where the Protection System is subject to one or more requirements in an Railbelt Reliability Council Standard.
 - 4.1.6.4. Each Cranking Path and group of Elements meeting the initial switching requirements from a Blackstart Resource up to and including the first interconnection point of the starting station service of the next generation unit(s) to be started.
 - 4.2. **Facilities:** For the purpose of the requirements contained herein, the following Facilities, systems, and equipment owned by each Responsible Entity in 4.1 above are those to which these requirements are applicable. For requirements in this standard where a specific type of

Facilities, system, or equipment or subset of Facilities, systems, and equipment are applicable, these are specified explicitly.

4.2.1. Distribution Provider: One or more of the following Facilities, systems and equipment owned by the Distribution Provider for the protection or restoration of the BES:

4.2.1.1. Each UFLS or UVLS System that:

4.2.1.1.1. is part of a Load shedding program that is subject to one or more requirements in an Railbelt Reliability Council Standard; and

4.2.1.1.2. performs automatic Load shedding under a common control system owned by the Responsible Entity, without human operator initiation, that the loss, compromise, or misuse of could have adverse impact on the reliable operation of the BES.

4.2.1.2. Each RAS where the RAS is subject to one or more requirements in an Railbelt Reliability Council Standard.

4.2.1.3. Each Protection System (excluding UFLS and UVLS) that applies to Transmission where the Protection System is subject to one or more requirements in an Railbelt Reliability Council Standard.

4.2.1.4. Each Cranking Path and group of Elements meeting the initial switching requirements from a Blackstart Resource up to and including the first interconnection point of the starting station service of the next generation unit(s) to be started.

4.2.2. Responsible Entities listed in 4.1 other than Distribution Providers:

All BES Facilities.

4.2.3. Exemptions: The following are exempt from Standard RRC-CIP-003-1:

4.2.3.1. Cyber Systems at Facilities regulated by the Canadian Nuclear Safety Commission.

4.2.3.2. Cyber Assets associated with communication networks and data communication links between discrete Electronic Security Perimeters (ESP).

4.2.3.3. Cyber Systems, associated with communication networks and data communication links, between Cyber Systems, providing confidentiality and integrity of an ESP that extends to one or more geographic locations.

4.2.3.4. The systems, structures, and components that are regulated by the Nuclear Regulatory Commission under a cyber security plan pursuant to 10 C.F.R. Section 73.54.

4.2.3.5. For Distribution Providers, the systems and equipment that are not included in section 4.2.1 above.

4.2.3.6. Responsible Entities that identify that they have no BES Cyber

Systems categorized as high impact or medium impact according to the CIP-002 identification and categorization processes.

- 4.3.** “Applicable Systems”: Each table has an “Applicable Systems” column to define the scope of systems to which a specific Requirement Part applies.
- 5. Effective Dates:** Requirements R3 and R4 shall become effective on the first day of the first calendar quarter, that is twelve (12) calendar months following adoption by the Approving Authority. Requirements R1 and R2 shall become effective on the first day of the first calendar quarter, that is thirty-six (36) calendar months following adoption by the Approving Authority.

B. Requirements and Measures

R1. Each Responsible Entity shall review and obtain CIP Senior Manager approval at least once every 15 calendar months for one or more documented cyber security policies that collectively address the following topics: *[Violation Risk Factor: Medium]*

1.1. For its high impact and medium impact BES Cyber Systems, if any:

1.1.1. Personnel and training (RRC-CIP-004);

1.1.2. Electronic Security Perimeters (RRC-CIP-005) including Interactive Remote Access;

1.1.3. Physical security of BES Cyber Systems (RRC-CIP-006);

1.1.4. System security management (RRC-CIP-007);

1.1.5. Incident reporting and response planning (RRC-CIP-008);

1.1.6. Recovery plans for BES Cyber Systems (RRC-CIP-009);

1.1.7. Configuration change management and vulnerability assessments (RRC-CIP-010);

1.1.8. Information protection (RRC-CIP-011); and

1.1.9. Declaring and responding to CIP Exceptional Circumstances.

1.2. For its assets identified in RRC-CIP-002 containing low impact BES Cyber Systems, if any:

1.2.1. Cyber security awareness;

1.2.2. Physical security controls;

1.2.3. Electronic access controls;

1.2.4. Cyber Security Incident response;

1.2.5. Transient Cyber Assets and Removable Media malicious code risk mitigation;

1.2.6. Vendor electronic remote access security controls; and

1.2.7. Declaring and responding to CIP Exceptional Circumstances.

M1. Examples of evidence may include, but are not limited to, policy documents; revision history, records of review, or workflow evidence from a document management system that indicate review of each cyber security policy at least once every 15 calendar months; and documented approval by the CIP Senior Manager for each cyber security policy.

R2. Each Responsible Entity with at least one asset identified in RRC-CIP-002 containing low impact BCS shall implement one or more documented cyber security plan(s) for its low impact BCS, and Shared Cyber Infrastructure (SCI) that supports a low impact BCS, that include the sections in Attachment 1. *[Violation Risk Factor: Lower] [Time Horizon: Operations Planning]*

Note: An inventory, list, or discrete identification of low impact BES Cyber Systems or their BES Cyber Assets is not required. Lists of authorized users are not required.

M2. Evidence shall include each of the documented cyber security plan(s) that collectively include

each of the sections in Attachment 1 and additional evidence to demonstrate implementation of the cyber security plan(s). Additional examples of evidence per section are located in Attachment 2.

- R3.** Each Responsible Entity shall identify a CIP Senior Manager by name and document any change within 30 calendar days of the change. *[Violation Risk Factor: Medium]*
- M3.** An example of evidence may include, but is not limited to, a dated and approved document from a high-level official designating the name of the individual identified as the CIP Senior Manager.
- R4.** The Responsible Entity shall implement a documented process to delegate authority, unless no delegations are used. Where allowed by the RRC-CIP Standards, the CIP Senior Manager may delegate authority for specific actions to a delegate or delegates. These delegations shall be documented, including the name or title of the delegate, the specific actions delegated, and the date of the delegation; approved by the CIP Senior Manager; and updated within 30 days of any change to the delegation. Delegation changes do not need to be reinstated with a change to the delegator. *[Violation Risk Factor: Lower]*
- M4.** An example of evidence may include, but is not limited to, a dated document, approved by the RRC-CIP Senior Manager, listing individuals (by name or title) who are delegated the authority to approve or authorize specifically identified items.

C. Compliance

1 Compliance Monitoring Process

1.1. Compliance Enforcement Authority:

The RRC is the entity with the authority to monitor and enforce compliance with mandatory and enforceable Railbelt Reliability Council Standards.

1.2. Evidence Retention:

The following evidence retention periods identify the period of time an entity is required to retain specific evidence to demonstrate compliance. For instances where the evidence retention period specified below is shorter than the time since the last audit, the RRC may ask an entity to provide other evidence to show that it was compliant for the full time period since the last audit.

The Responsible Entity shall keep data or evidence to show compliance as identified below unless directed by its RRC to retain specific evidence for a longer period of time as part of an investigation:

- Each Responsible Entity shall retain evidence of each requirement in this standard for three calendar years.
- If a Responsible Entity is found non-compliant, it shall keep information related to the non-compliance until mitigation is complete and approved or for the time specified above, whichever is longer.
- The RRC shall keep the last audit records and all requested and submitted subsequent audit records.

1.3. Compliance Monitoring and Enforcement Program:

Compliance Monitoring and Enforcement Program refers to the identification of the processes that will be used to evaluate data or information for the purpose of assessing performance or outcomes with the associated Railbelt Reliability Council Standards.

D. Table of Compliance Elements

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-003-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
R1	Medium	The Responsible Entity did not address one of the nine topics required by Requirement R1. (R 1.1)	The Responsible Entity did not address two of the nine topics required by Requirement R1. (R 1.1)	The Responsible Entity did not address four of the nine topics required by Requirement R1. (R 1.1)	The Responsible Entity did not address six or more of the nine topics required by Requirement R1. (R 1.1)
		OR	OR	OR	OR
		The Responsible Entity did not complete its review of the one or more documented cyber security policies for its high impact and medium impact BCS as required by Requirement R1 within 15 calendar months but did complete this review in less than or equal to 17 calendar months of the previous review. (R 1.1)	The Responsible Entity did not complete its review of the one or more documented cyber security policies for its high impact and medium impact BCS as required by Requirement R1 within 17 calendar months but did complete this review in less than or equal to 19 calendar months of the previous review. (R 1.1)	The Responsible Entity did not complete its review of the one or more documented cyber security policies for its high impact and medium impact BCS as required by Requirement R1 within 19 calendar months but did complete this review in less than or equal to 21 calendar months of the previous review. (R 1.1)	The Responsible Entity did not have any documented cyber security policies for its high impact and medium impact BCS as required by Requirement R1. (R 1.1)
		OR	OR	OR	OR
		The Responsible Entity did not complete its approval of the one or more documented cyber security policies for its high impact and medium impact BCS as required by Requirement R1 by the CIP Senior Manager	The Responsible Entity did not complete its approval of the one or more documented cyber security policies for its high impact and medium impact BCS as required by Requirement R1 by the CIP Senior Manager within 17 calendar months but did complete this approval in	The Responsible Entity did not complete its approval of the one or more documented cyber security policies for its high impact and medium impact BCS as required by Requirement R1 by the CIP Senior Manager within 19	The Responsible Entity did not complete its review of the one or more documented cyber security policies as required by Requirement R1 within 18 calendar months of the previous review. (Requirement R1)
					OR
					The Responsible Entity did not complete its approval

Railbelt Reliability Council Standard RRC-CIP-003-1 — Cyber Security – Security Management Controls

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-003-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
		within 15 calendar months but did complete this approval in less than or equal to 17 calendar months of the previous approval. (R 1.1) OR The Responsible Entity documented one or more cyber security policies for its assets identified in CIP-002 containing low impact BCS, but did not address one of the seven topics required by Requirement R1. (R 1.2) OR The Responsible Entity did not complete its review of the one or more documented cyber security policies for its assets identified in CIP-002 containing low impact BCS as required by Requirement R1 within 15 calendar months but did complete this review in less than or equal to 17 calendar months of the previous review. (R 1.2)	less than or equal to 19 calendar months of the previous approval. (R 1.1) OR The Responsible Entity documented one or more cyber security policies for its assets identified in CIP-002 containing low impact BCS, but did not address two of the seven topics required by Requirement R1. (R 1.2) OR The Responsible Entity did not complete its review of the one or more documented cyber security policies for its assets identified in CIP-002 containing low impact BCS as required by Requirement R1 within 17 calendar months but did complete this review in less than or equal to 19 calendar months of the previous review. (R 1.2) OR	calendar months but did complete this approval in less than or equal to 21 calendar months of the previous approval. (Requirement R1) OR The Responsible Entity documented one or more cyber security policies for its assets identified in CIP-002 containing low impact BCS, but did not address four of the seven topics required by Requirement R1. (R 1.2) OR The Responsible Entity did not complete its review of the one or more documented cyber security policies for its assets identified in CIP-002 containing low impact BCS as required by Requirement R1 within 19 calendar months but did complete this review in less than or equal to 21 calendar months of the previous review. (R 1.2)	of the one or more documented cyber security policies for its high impact and medium impact BCS as required by Requirement R1 by the CIP Senior Manager within 21 calendar months of the previous approval. (R 1.1) OR The Responsible Entity did not address six or more of the seven topics required by Requirement R1. (R 1.2) OR The Responsible Entity did not have any documented cyber security policies for its assets identified in CIP-002 containing low impact BCS as required by Requirement R1. (R1.2) OR The Responsible Entity did not complete its approval of the one or more

Railbelt Reliability Council Standard RRC-CIP-003-1 — Cyber Security – Security Management Controls

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-003-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
		OR The Responsible Entity did not complete its approval of the one or more documented cyber security policies for its assets identified in CIP-002 containing low impact BCS as required by Requirement R1 by the CIP Senior Manager within 15 calendar months but did complete this approval in less than or equal to 17 calendar months of the previous approval. (R 1.2)	The Responsible Entity did not complete its approval of the one or more documented cyber security policies for its assets identified in CIP-002 containing low impact BCS as required by Requirement R1 by the CIP Senior Manager within 17 calendar months but did complete this approval in less than or equal to 19 calendar months of the previous approval. (R 1.2)	OR The Responsible Entity did not complete its approval of the one or more documented cyber security policies for its assets identified in CIP-002 containing low impact BCS as required by Requirement R1 by the CIP Senior Manager within 19 calendar months but did complete this approval in less than or equal to 21 calendar months of the previous approval. (R 1.2)	documented cyber security policies for its assets identified in CIP-002 containing low impact BCS as required by Requirement R1 by the CIP Senior Manager within 21 calendar months of the previous approval. (R1.2)
R2	Lower	The Responsible Entity failed to document cyber security awareness according to Requirement R2, Attachment 1, Section 1. (Requirement R2) OR The Responsible Entity failed to document its cyber security plan(s) for electronic access controls according to Requirement R2, Attachment 1, Section 3. (Requirement R2) OR	The Responsible Entity failed to reinforce cyber security practices at least once every 15 calendar months according to Requirement R2, Attachment 1, Section 1. (Requirement R2) OR The Responsible Entity failed to document physical security controls according to Requirement R2, Attachment 1, Section 2. (Requirement R2) OR	The Responsible Entity failed to implement the physical security controls according to Requirement R2, Attachment 1, Section 2. (Requirement R2) OR The Responsible Entity failed to permit only necessary inbound and outbound electronic access controls according to Requirement R2, Attachment 1, Section 3.1. (Requirement R2)	The Responsible Entity failed to document and implement one or more cyber security plan(s) according to Requirement R2, Attachment 1. (Requirement R2)

Railbelt Reliability Council Standard RRC-CIP-003-1 — Cyber Security – Security Management Controls

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-003-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
		The Responsible Entity failed to document one or more Cyber Security Incident response plan(s) according to Requirement R2, Attachment 1, Section 4. (Requirement R2) OR The Responsible Entity failed to update each Cyber Security Incident response plan(s) within 180 days according to Requirement R2, Attachment 1, Section 4. (Requirement R2) OR The Responsible Entity failed to manage its Transient Cyber Asset(s) according to Requirement R2, Attachment 1, Section 5.1. (Requirement R2) OR The Responsible Entity failed to document the Removable Media section(s) according to Requirement R2, Attachment	The Responsible Entity failed to document electronic access controls according to Requirement R2, Attachment 1, Section 3. (Requirement R2) OR The Responsible Entity failed to implement authentication for all Dial-up Connectivity according to Requirement R2, Attachment 1, Section 3.2 (Requirement R2) OR The Responsible Entity failed to include the process for identification, classification, and response to Cyber Security Incidents according to Requirement R2, Attachment 1, Section 4. (Requirement R2) OR The Responsible Entity failed to document the determination of whether an identified Cyber Security Incident is a	OR The Responsible Entity documented failed to test each Cyber Security Incident response plan(s) at least once every 36 calendar months according to Requirement R2, Attachment 1, Section 4. (Requirement R2) OR The Responsible Entity failed to notify the Electricity Information Sharing and Analysis Center (E-ISAC) according to Requirement R2, Attachment 1, Section 4. (Requirement R2) OR The Responsible Entity failed to implement mitigation for the introduction of malicious code for Transient Cyber Assets managed by the Responsible Entity according to Requirement R2, Attachment 1, Section 5.1. (Requirement R2)	

Railbelt Reliability Council Standard RRC-CIP-003-1 — Cyber Security – Security Management Controls

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-003-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
		1, Section 5.3. (Requirement R2) OR The Responsible Entity implemented vendor electronic remote access security controls but failed to document its cyber security process for vendor electronic remote access security controls according to Requirement R2, Attachment 1, Section 6 (Requirement R2)	Reportable Cyber Security Incident and subsequent notification to the Electricity Information Sharing and Analysis Center (E-ISAC) according to Requirement R2, Attachment 1, Section 4. (Requirement R2) OR The Responsible Entity failed to document mitigation for the introduction of malicious code for Transient Cyber Assets managed by the Responsible Entity according to Requirement R2, Attachment 1, Sections 5.1 and 5.3. (Requirement R2) OR The Responsible Entity failed to document mitigation for the introduction of malicious code for Transient Cyber Assets managed by a party other than the Responsible Entity according to Requirement R2, Attachment 1, Section 5.2. (Requirement R2)	OR The Responsible Entity failed to implement mitigation for the introduction of malicious code for Transient Cyber Assets managed by a party other than the Responsible Entity according to Requirement R2, Attachment 1, Section 5.2. (Requirement R2) OR The Responsible Entity failed to implement mitigation for the threat of detected malicious code on the Removable Media prior to connecting Removable Media according to Requirement R2, Attachment 1, Section 5.3. (Requirement R2) OR The Responsible Entity failed to document and implement its cyber security process for vendor electronic remote	

Railbelt Reliability Council Standard RRC-CIP-003-1 — Cyber Security – Security Management Controls

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-003-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
			OR The Responsible Entity failed to implement the Removable Media section(s) according to Requirement R2, Attachment 1, Section 5.3. (Requirement R2) OR The Responsible Entity documented its cyber security process for vendor electronic remote access security controls but failed to implement vendor electronic remote access security controls according to Requirement R2. Attachment 1, Section 6. (Requirement R2)	access security controls according to Requirement R2, Attachment 1, Section 6. (Requirement R2)	

Railbelt Reliability Council Standard RRC-CIP-003-1 — Cyber Security – Security Management Controls

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-003-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
R3	Medium	The Responsible Entity did not document changes to the CIP Senior Manager within 30 calendar days but did document this change in less than 40 calendar days of the change. (Requirement R3)	The Responsible Entity did not document changes to the CIP Senior Manager within 40 calendar days but did document this change in less than 50 calendar days of the change. (Requirement R3)	The Responsible Entity did not document changes to the CIP Senior Manager within 50 calendar days but did document this change in less than 60 calendar days of the change. (Requirement R3)	The Responsible Entity did not identify, by name, a CIP Senior Manager. OR The Responsible Entity did not document changes to the CIP Senior Manager within 60 calendar days of the change. (Requirement R3)
R4	Lower	The Responsible Entity did not document changes to the delegate within 30 calendar days but did document this change in less than 45 calendar days of the change. (Requirement R4)	The Responsible Entity did not document changes to the delegate within 45 calendar days but did document this change in less than 60 calendar days of the change. (Requirement R4)	The Responsible Entity did not document changes to the delegate within 60 calendar days but did document this change in less than 75 calendar days of the change. (Requirement R4)	The Responsible Entity does not have a process to delegate actions from the CIP Senior Manager. (Requirement R4) OR The Responsible Entity did not document changes to the delegate within 75 calendar days of the change. (Requirement R4)

E. Regional Variances

None.

F. Interpretations

None.

G. Associated Documents

None.

Version History

Version	Date	Action	Change Tracking

Attachment 1

Required Sections for Cyber Security Plan(s)

Responsible Entities shall include each of the sections provided below in the cyber security plan(s) required under Requirement R2.

Responsible Entities with multiple-impact BCS ratings can utilize policies, procedures, and processes for their high or medium impact BCS to fulfill the sections for the development of low impact cyber security plan(s). Each Responsible Entity can develop a cyber security plan(s) either by individual asset or groups of assets.

Section 1. Cyber Security Awareness: Each Responsible Entity shall reinforce, at least once every 15 calendar months, cyber security practices (which may include associated physical security practices).

Section 2. Physical Security Controls: Each Responsible Entity shall control physical access, based on need as determined by the Responsible Entity, to (1) the asset or the locations of the low impact BCS within the asset, and (2) the Cyber Asset(s) or VCA, as specified by the Responsible Entity, that provide electronic access control(s) implemented for Section 3.1, if any.

Section 3. Electronic Access Controls: For each asset containing low impact BES Cyber System(s) identified pursuant to CIP-002, the Responsible Entity shall implement electronic access controls to:

3.1 Permit only necessary inbound and outbound electronic access as determined by the Responsible Entity for any communications that are:

i. Between:

- a low impact BCS; or
- An SCI that supports a low impact BCS

and a Cyber System(s) outside the asset containing:

- the low impact BCS(s); or
- the SCI that supports a low impact BCS;

ii. using a routable protocol when entering or leaving the asset containing the low impact BCS or SCI that supports a low impact BCS; and

iii. not used for time-sensitive communications of Protection Systems.

3.2 Authenticate all Dial-up Connectivity, if any, that provides access to low impact BCS or SCI that supports a low impact BCS, per system capability.

Section 4. Cyber Security Incident Response: Each Responsible Entity shall have one or more Cyber Security Incident response plan(s), either by asset or group of assets, which shall include:

4.1 Identification, classification, and response to Cyber Security Incidents;

4.2 Determination of whether an identified Cyber Security Incident is a Reportable Cyber Security Incident and subsequent notification to the Electricity Information Sharing and Analysis Center (E-ISAC), unless prohibited by law;

4.3 Identification of the roles and responsibilities for Cyber Security Incident response by groups or individuals;

4.4 Incident handling for Cyber Security Incidents;

4.5 Testing the Cyber Security Incident response plan(s) at least once every 36 calendar months by: (1) responding to an actual Reportable Cyber Security Incident; (2) using a drill or tabletop exercise of a Reportable Cyber Security Incident; or (3) using an operational exercise of a Reportable Cyber Security Incident; and

4.6 Updating the Cyber Security Incident response plan(s), if needed, within 180 calendar days after completion of a Cyber Security Incident response plan(s) test or actual Reportable Cyber Security Incident.

Section 5. TCA and Removable Media Malicious Code Risk Mitigation: Each Responsible Entity shall implement, except under CIP Exceptional Circumstances, one or more plan(s) to achieve the objective of mitigating the risk of the introduction of malicious code to low impact BCS, through the use of TCA or Removable Media. The plan(s) shall include:

5.1 For TCA managed by the Responsible Entity, if any, the use of one or a combination of the following in an ongoing or on-demand manner (per TCA capability):

- Antivirus software, including manual or managed updates of signatures or patterns;
- Application whitelisting; or
- Other method(s) to mitigate the introduction of malicious code.

5.2 For TCA managed by a party other than the Responsible Entity, if any:

5.2.1 Use one or a combination of the following prior to connecting (per TCA capability):

- Review of antivirus update level;
- Review of antivirus update process used by the party;
- Review of application whitelisting used by the party;
- Review of system hardening used by the party; or
- Review of other method(s) to mitigate the risk of introduction of malicious code.

5.2.2 For any method used pursuant to 5.2.1, Responsible Entities shall determine whether any additional mitigation actions are necessary and implement such actions prior to connecting the TCA.

5.3 For Removable Media, the use of each of the following:

5.3.1 Method(s) to detect malicious code on Removable Media using a Cyber Asset or VCA other than a BCS or SCI that supports a low impact BCS; and

5.3.2 Mitigation of the threat of detected malicious code on the Removable Media prior to connecting Removable Media to a low impact BCS or SCI that supports a low impact BCS.

Section 6. Vendor Electronic Remote Access Security Controls: For assets containing low impact BES Cyber

Attachment 1

System(s) identified pursuant to CIP-002, that allow vendor electronic remote access, the Responsible Entity shall implement a process to mitigate risks associated with vendor electronic remote access, where such access has been established under Section 3.1. These processes shall include:

- 6.1** One or more method(s) for determining vendor electronic remote access;
- 6.2** One or more method(s) for disabling vendor electronic remote access; and
- 6.3** One or more method(s) for detecting known or suspected inbound and outbound malicious communications for vendor electronic remote access.

Attachment 2

Examples of Evidence for Cyber Security Plan(s)

Section 1. Cyber Security Awareness: An example of evidence for Section 1 may include, but is not limited to, documentation that the reinforcement of cyber security practices occurred at least once every 15 calendar months. The evidence could be documentation through one or more of the following methods:

- Direct communications (for example, e-mails, memos, or computer-based training);
- Indirect communications (for example, posters, intranet, or brochures); or
- Management support and reinforcement (for example, presentations or meetings).

Section 2. Physical Security Controls: Examples of evidence for Section 2 may include, but are not limited to:

- Documentation of the selected access control(s) (e.g., card key, locks, perimeter controls), monitoring controls (e.g., alarm systems, human observation), or other operational, procedural, or technical physical security controls that control physical access to both:
 - a. The asset, if any, or the locations of the low impact BCS within the asset; and
 - b. The Cyber System(s) specified by the Responsible Entity that provide(s) electronic access controls implemented for Attachment 1, Section 3.1, if any.

Section 3. Electronic Access Controls: Examples of evidence for Section 3 may include, but are not limited to:

1. Documentation showing that at each asset or group of assets, the routable protocol communication as outlined in Section 3 is restricted by electronic access controls to permit only inbound and outbound electronic access that the Responsible Entity deems necessary, except where an entity provides rationale that communications are used for time-sensitive communications of Protection Systems. Examples of such documentation may include, but are not limited to representative diagrams that illustrate control of inbound and outbound communication(s) or lists of implemented electronic access controls (e.g., access control lists restricting IP addresses, ports, or services; implementing unidirectional gateways).
2. Documentation of authentication for Dial-up Connectivity (e.g., dial out only to a preprogrammed number to deliver data, dial-back modems, modems that must be remotely controlled by the control center or control room, or access control on the BCS).

Section 4. Cyber Security Incident Response: An example of evidence for Section 4 may include, but is not limited to, dated documentation, such as policies, procedures, or process documents of one or more Cyber Security Incident response plan(s) developed either by asset or group of assets that include the following processes:

1. to identify, classify, and respond to Cyber Security Incidents; to determine whether an identified Cyber Security Incident is a Reportable Cyber Security Incident and for notifying the Electricity Information Sharing and Analysis Center (E-ISAC);
2. to identify and document the roles and responsibilities for Cyber Security Incident response by

- groups or individuals (e.g., initiating, documenting, monitoring, reporting, etc.);
3. for incident handling of a Cyber Security Incident (e.g., containment, eradication, or recovery/incident resolution);
 4. for testing the plan(s) along with the dated documentation that a test has been completed at least once every 36 calendar months; and
 5. to update, as needed, Cyber Security Incident response plan(s) within 180 calendar days after completion of a test or actual Reportable Cyber Security Incident.

Section 5. TCA and Removable Media Malicious Code Risk Mitigation:

1. Examples of evidence for Section 5.1 may include, but are not limited to, documentation of the method(s) used to mitigate the introduction of malicious code such as antivirus software and processes for managing signature or pattern updates, application whitelisting practices, processes to restrict communication, or other method(s) to mitigate the introduction of malicious code. If a TCA does not have the capability to use method(s) that mitigate the introduction of malicious code, evidence may include documentation by the vendor or Responsible Entity that identifies that the TCA does not have the capability.
2. Examples of evidence for Section 5.2.1 may include, but are not limited to, documentation from change management systems, electronic mail or procedures that document a review of the installed antivirus update level; memoranda, electronic mail, system documentation, policies or contracts from the party other than the Responsible Entity that identify the antivirus update process, the use of application whitelisting, use of system hardening performed by the party other than the Responsible Entity; evidence from change management systems, electronic mail or contracts that identifies the Responsible Entity's acceptance that the practices of the party other than the Responsible Entity are acceptable; or documentation of other method(s) to mitigate malicious code for TCA managed by a party other than the Responsible Entity. If a TCA does not have the capability to use method(s) that mitigate the introduction of malicious code, evidence may include documentation by the Responsible Entity or the party other than the Responsible Entity that identifies that the TCA does not have the capability.
3. Examples of evidence for Attachment 1, Section 5.2.2 may include, but are not limited to, documentation from change management systems, electronic mail, or contracts that identifies a review to determine whether additional mitigation is necessary and has been implemented prior to connecting the TCA managed by a party other than the Responsible Entity.
4. Examples of evidence for Section 5.3.1 may include, but are not limited to, documented process(es) of the method(s) used to detect malicious code such as results of scan settings for Removable Media, or implementation of on-demand scanning. Examples of evidence for Section 5.3.2 may include, but are not limited to, documented process(es) for the method(s) used for mitigating the threat of detected malicious code on Removable Media, such as logs from the method(s) used to detect malicious code that show the results of scanning and the mitigation of detected malicious code on Removable Media or documented confirmation by the entity that the Removable Media was deemed to be free of malicious code

Section 6. Vendor Electronic Remote Access Security Controls: Examples of evidence showing the implementation of the process for Section 6 may include, but are not limited to:

1. For Section 6.1, documentation showing:
 - steps to preauthorize access;
 - alerts generated by vendor log on;
 - session monitoring;
 - security information management logging alerts;
 - time-of-need session initiation;
 - session recording;
 - system logs; or
 - other operational, procedural, or technical controls.
2. For Section 6.2, documentation showing:
 - disabling vendor electronic remote access user or system accounts;
 - disabling inbound and/or outbound hardware or software ports, services, or access permissions on applications, firewall, IDS/IPS, router, switch, VPN, Remote Desktop, remote control, or other hardware or software used for providing vendor electronic remote access;
 - disabling communications protocols (such as IP) used for systems which establish and/or maintain vendor electronic remote access;
 - Removing physical layer connectivity (e.g., disconnect an Ethernet cable, power down equipment);
 - administrative control documentation listing the methods, steps, or systems used to disable vendor electronic remote access; or
 - other operational, procedural, or technical controls.
3. For Section 6.3, documentation showing implementation of processes or technologies which have the ability to detect malicious communications such as:
 - Anti-malware technologies;
 - Intrusion Detection System (IDS)/Intrusion Prevention System (IPS);
 - Automated or manual log reviews;
 - alerting; or
 - other operational, procedural, or technical controls.

GLOSSARY

Balancing Authority	The responsible entity that integrates resource plans ahead of time, maintains Demand and resource balance within a Balancing Authority Area, and supports Interconnection frequency in real time.
BES Cyber Asset (BCA)	A Cyber Asset that if rendered unavailable, degraded, or misused would, within 15 minutes of its required operation, misoperation, or non operation, adversely impact one or more Facilities, systems, or equipment, which, if destroyed, degraded, or otherwise rendered unavailable when needed, would affect the reliable operation of the Bulk Electric System. Redundancy of affected Facilities, systems, and equipment shall not be considered when determining adverse impact. Each BES Cyber Asset is included in one or more BES Cyber Systems.
BES Cyber System (BCS)	One or more BES Cyber Assets logically grouped by a responsible entity to perform one or more reliability tasks for a functional entity.
BES Cyber System Information	Information about the BES Cyber System that could be used to gain unauthorized access or pose a security threat to the BES Cyber System. BES Cyber System Information does not include individual pieces of information that by themselves do not pose a threat or could not be used to allow unauthorized access to BES Cyber Systems, such as, but not limited to, device names, individual IP addresses without context, ESP names, or policy statements. Examples of BES Cyber System Information may include, but are not limited to, security procedures or security information about BES Cyber Systems, Physical Access Control Systems, and Electronic Access Control or Monitoring Systems that is not publicly available and could be used to allow unauthorized access or unauthorized distribution; collections of network addresses; and network topology of the BES Cyber System.
Blackstart Resource	A generating unit(s) and its associated set of equipment which has the ability to be started without support from the System or is designed to remain energized without connection to the remainder of the System, with the ability to energize a bus, meeting the Transmission Operator's restoration plan needs for Real and Reactive Power capability, frequency and voltage control, and that has been included in the Transmission Operator's restoration plan.

Bulk Electric System (BES)	Unless modified by the lists shown below, all Transmission Elements operated at 100 kV or higher and Real Power and Reactive Power resources connected at 100 kV or higher. This does not include facilities used in the local distribution of electric energy. Inclusions: • I1 - Transformers with the primary terminal and at least one secondary terminal operated at 100 kV or higher unless excluded by application of Exclusion E1 or E3. • I2 – Generating resource(s) including the generator terminals through the high-side of the step-up transformer(s) connected at a voltage of 100 kV or above with: a) Gross individual nameplate rating greater than 20 MVA. Or, b) Gross plant/facility aggregate nameplate rating greater than 75 MVA. • I3 - Blackstart Resources identified in the Transmission Operator’s restoration plan. • I4 - Dispersed power producing resources that aggregate to a total capacity greater than 75 MVA (gross nameplate rating), and that are connected through a system designed primarily for delivering such capacity to a common point of connection at a voltage of 100 kV or above. Thus, the facilities designated as BES are: a) The individual resources, and The system designed primarily for delivering capacity from the point where those resources aggregate to greater than 75 MVA to a common point of connection at a voltage of 100 kV or above. • I5 –Static or dynamic devices (excluding generators) dedicated to supplying or absorbing Reactive Power that are connected at 100 kV or higher, or through a dedicated transformer with a high-side voltage of 100 kV or higher, or through a transformer that is designated in Inclusion I1 unless excluded by application of Exclusion E4 Exclusions: • E1 - Radial systems: A group of contiguous transmission Elements that emanates from a single point of connection of 100 kV or higher and: a) Only serves Load. Or, b) Only includes generation resources, not identified in Inclusions I2, I3, or I4, with an aggregate capacity less than or equal to 75 MVA (gross nameplate rating). Or, c) Where the radial system serves Load and includes generation resources, not identified in Inclusions I2, I3 or I4, with an aggregate capacity of non- retail generation less than or equal to 75 MVA (gross nameplate rating). Note 1 – A normally open switching device between radial systems, as
-----------------------------------	---

	depicted on prints or one-line diagrams for example, does not affect this exclusion. Note 2 – The presence of a contiguous loop, operated at a voltage level of 50 kV or less, between configurations being considered as radial systems, does not affect this exclusion. • E2 - A generating unit or multiple generating units on the customer's side of the retail meter that serve all or part of the retail Load with electric energy if: (i) the net capacity provided to the BES does not exceed 75 MVA, and (ii) standby, back-up, and maintenance power services are provided to the generating unit or multiple generating units or to the retail Load by a Balancing Authority, or provided pursuant to a binding obligation with a Generator Owner or Generator Operator, or under terms approved by the applicable regulatory authority. • E3 - Local networks (LN): A group of contiguous transmission Elements operated at less than 300 kV that distribute power to Load rather than transfer bulk power across the interconnected system. LN's emanate from multiple points of connection at 100 kV or higher to improve the level of service to retail customers and not to accommodate bulk power transfer across the interconnected system. The LN is characterized by all of the following: a) Limits on connected generation: The LN and its underlying Elements do not include generation resources identified in Inclusions I2, I3, or I4 and do not have an aggregate capacity of non-retail generation greater than 75 MVA (gross nameplate rating); b) Real Power flows only into the LN and the LN does not transfer energy originating outside the LN for delivery through the LN; and c) Not part of a Flowgate or transfer path: The LN does not contain any part of a permanent Flowgate in the Eastern Interconnection, a major transfer path within the Western Interconnection, or a comparable monitored Facility in the ERCOT or Quebec Interconnections, and is not a monitored Facility included in an Interconnection Reliability Operating Limit (IROL). • E4 – Reactive Power devices installed for the sole benefit of a retail customer(s). Note - Elements may be included or excluded on a case-by-case basis through b) the Rules of Procedure exception process.
CIP Exceptional Circumstance	A situation that involves or threatens to involve one or more of the following, or similar, conditions that impact safety or BES reliability: a risk of injury or death; a natural disaster; civil unrest; an imminent or existing hardware, software, or equipment failure; a Cyber Security Incident requiring emergency assistance; a response by emergency services; the enactment of a mutual assistance agreement; or an impediment of large

Glossary

	scale workforce availability.
CIP Senior Manager	A single official with the authority to bind the registered entity to adhere to the requirements within the CIP Standards, CIP-002 through CIP-015.
Control Center	One or more facilities hosting operating personnel that monitor and control the Bulk Electric System (BES) in real-time to perform the reliability tasks, including their associated data centers, of: 1) a Reliability Coordinator, 2) a Balancing Authority, 3) a Transmission Operator for transmission Facilities at two or more locations, or 4) a Generator Operator for generation Facilities at two or more locations.
Cranking Path	A portion of the electric system that can be isolated and then energized to deliver electric power from a generation source to enable the startup of one or more other generating units.
Cyber Assets	Programmable electronic devices, including the hardware, software, and data in those devices.
Distribution Provider	Provides and operates the “wires” between the transmission system and the end-use customer. For those end-use customers who are served at transmission voltages, the Transmission Owner also serves as the Distribution Provider. Thus, the Distribution Provider is not defined by a specific voltage, but rather as performing the distribution function at any voltage
Electronic Access Control or Monitoring Systems	Cyber Assets that perform electronic access control or electronic access monitoring of the Electronic Security Perimeter(s) or BES Cyber Systems. This includes Intermediate Systems.
Electronic Access Point	A Cyber Asset interface on an Electronic Security Perimeter that allows routable communication between Cyber Assets outside an Electronic Security Perimeter and Cyber Assets inside an Electronic Security Perimeter.
Electronic Security Perimeter	The logical border surrounding a network to which BES Cyber Systems are connected using a routable protocol.
Element	Any electrical device with terminals that may be connected to other electrical devices such as a generator, transformer, circuit breaker, bus section, or transmission line. An Element may be comprised of one or

Glossary

	more components.
Shared Cyber Infrastructure	One or more programmable electronic devices, including the software that shares the devices' resources, that: • Hosts one or more Virtual Cyber Assets (VCA) included in a BES Cyber Systems (BCS) or their associated Electronic Access Control or Monitoring Systems (EACMS) or Physical Access Control Systems (PACS); and hosts one or more VCAs that are not included in, or associated with, BCS of the same impact categorization; or • Provides storage resources required for system functionality of one or more Cyber Assets or VCAs included in a BCS or their associated EACMS or PACS; and also for one or more Cyber Assets or VCAs that are not included in, or associated with, BCS of the same impact categorization. SCI does not include the supported VCAs or Cyber Assets with which it shares its resources.
Transient Cyber Asset	A Cyber Asset that is: 1. capable of transmitting or transferring executable code, 2. not included in a BES Cyber System, 3. not a Protected Cyber Asset (PCA) associated with high or medium impact BES Cyber Systems, and 4. directly connected (e.g., using Ethernet, serial, Universal Serial Bus, or wireless including near field or Bluetooth communication) for 30 consecutive calendar days or less to a: • BES Cyber Asset, • network within an Electronic Security Perimeter (ESP) containing high or medium impact BES Cyber Systems, or • PCA associated with high or medium impact BES Cyber Systems. Examples of Transient Cyber Assets include, but are not limited to, Cyber Assets used for data transfer, vulnerability assessment, maintenance, or troubleshooting purposes.